

Week 5 Project Deliverable

Cybersecurity Framework Profiling and Third-Party Risk Operationalization for PaySphere

GRC Analyst Self-Curated Curriculum — Week 5

Executive Summary

This Week 5 project focused on translating previously identified cybersecurity and governance risks into structured, actionable Governance, Risk, and Compliance (GRC) artifacts.

The project involved two practical exercises:

1. **Developing a NIST Cybersecurity Framework (CSF) 2.0 Current and Target Profile for PaySphere**
2. **Creating an operational Vendor Risk Record for a critical third-party supplier, Razorpay**

The purpose of these exercises was to move beyond identifying risks and controls and demonstrate how a GRC analyst can use a cybersecurity framework to:

- Assess an organization's current cybersecurity posture
- Define a desired target state
- Identify explicit gaps between current and target capabilities
- Prioritize remediation based on known organizational risks
- Operationalize third-party risk management requirements
- Establish vendor monitoring and review mechanisms
- Document risk ownership and risk acceptance decisions

The resulting artifacts demonstrate the practical application of **NIST CSF 2.0**, risk management principles, vendor risk assessment, control gap analysis, governance, and risk treatment.

1. Organization Background and Project Scope

PaySphere is a hypothetical payment processing organization whose cybersecurity and compliance environment has been assessed throughout the earlier stages of this curriculum.

The Week 5 deliverables build upon previously identified organizational risks, including:

- Privileged access weaknesses
- Critical vendor concentration
- Incomplete vendor assessments
- Absence of a formal Business Continuity and Disaster Recovery program
- Merchant portal security vulnerabilities
- Limited endpoint monitoring
- Gaps in security governance and policy management

The scope of the cybersecurity profile includes:

- PaySphere payment processing platform
- AWS Mumbai infrastructure
- DevOps environment
- Customer Support functions

The selected NIST CSF 2.0 Subcategories were prioritized based on their relevance to the existing PaySphere risk register, including risks PSR-001 through PSR-008.

2. Project A — PaySphere NIST CSF 2.0 Current and Target Profile

2.1 Objective

The objective of this project was to develop a focused **NIST Cybersecurity Framework 2.0 Profile** that compares PaySphere's current cybersecurity posture against a defined target state.

Rather than assessing every NIST CSF 2.0 Subcategory, the Profile focuses on the areas most relevant to PaySphere's known risks.

For each selected Subcategory, the assessment documents:

- The current state of implementation
- The desired target state
- The explicit capability or control gap

This approach enables the Profile to function as a practical roadmap for security and compliance improvement rather than simply a framework checklist.

2.2 Organizational Cybersecurity Tier Assessment

Current Tier: Tier 2 — Risk Informed

PaySphere demonstrates awareness of cybersecurity risks and maintains a documented risk register. Basic security controls are also present across parts of the environment.

However, risk management practices are not consistently formalized or applied across the organization. Security decisions are frequently made at the team level without a consistently documented risk appetite, governance structure, or policy baseline.

Characteristics of the current state include:

- Informal risk ownership
 - Limited executive-level risk governance
 - Inconsistent policy implementation
 - Incomplete vendor monitoring
 - Controls operating without sufficient formal documentation
 - Ad hoc decision-making in several security domains
-

Target Tier: Tier 3 — Repeatable

The target state for PaySphere is a Repeatable cybersecurity risk management approach.

In this target environment:

- Formal security policies are established and consistently applied
 - Risk ownership is documented
 - Risk-informed decisions are aligned with leadership-approved risk appetite
 - Third-party risks are assessed and monitored on a defined cadence
 - Security controls operate within documented governance processes
 - Cybersecurity activities are consistently repeatable across the organization
-

3. NIST CSF 2.0 Profile Assessment

3.1 GOVERN Function

GV.RM-01 — Risk Management Objectives Established by Leadership

Assessment Area	Profile
Current Profile	No formal risk appetite statement exists. Security risk decisions are frequently delegated to engineering leads closest to the issue. Although the PaySphere risk register exists, it has not been formally commissioned by or incorporated into regular executive or board-level governance activities.

Assessment Area	Profile
Target Profile	A board-approved risk appetite statement defines tolerance levels for key cybersecurity and business risks, including data exposure, platform downtime, and third-party failure. The risk register is reviewed as part of a recurring executive or board governance process.
Gap	No documented risk appetite exists. Executive-level accountability for cybersecurity risk is limited, and the risk register operates without a formal leadership mandate.

GV.RR-02 — Cybersecurity Roles and Responsibilities Established and Communicated

Assessment Area	Profile
Current Profile	Cybersecurity ownership is largely informal. Security responsibilities are generally perceived as belonging to the security team, and individual ownership of specific risks is not consistently documented.
Target Profile	A documented RACI model assigns ownership for all significant risks. For example, privileged access and application vulnerabilities have designated security ownership, BCDR has infrastructure ownership, and vendor or regulatory risks have compliance ownership.
Gap	No formal RACI exists, and risk accountability is assumed rather than explicitly assigned.

GV.PO-01 — Policy for Managing Cybersecurity Risk Established

Assessment Area	Profile
Current Profile	Key policies are missing or incomplete, including formal access control and security awareness requirements. Security decisions are often made in response to incidents rather than through an established policy framework.
Target Profile	A minimum governance policy set is implemented, including an Information Security Policy, Access Control Policy, Vendor Risk Management Policy, and Incident Response Policy. Policies are approved by appropriate leadership, version-controlled, and reviewed annually.
Gap	Controls are operating without an adequate policy backbone, creating governance and audit readiness concerns.

GV.SC-07 — Supplier Risks Understood, Recorded, Prioritized, and Monitored

Assessment Area	Profile
Current Profile	Vendor concentration risk has been identified at a high level, but individual vendor risk records are incomplete. Some critical vendors have contractual documentation, while others have not been formally assessed. No consistent monitoring cadence exists.
Target Profile	A vendor risk record exists for each critical supplier and includes vendor criticality, data access scope, security attestations, contractual obligations, assessment history, and review dates. Critical vendors are monitored on a recurring basis with defined escalation triggers.
Gap	Vendor assessments are incomplete, monitoring is inconsistent, and no standardized process exists for tracking supplier security posture changes.

4. PROTECT Function

PR.AA-05 — Access Permissions Managed Using Least Privilege and Separation of Duties

Assessment Area	Profile
Current Profile	Standing administrative access exists within the production environment. Formal access review processes are not established, and separation of duties between DevOps and database administration functions is not consistently documented. MFA is available but not uniformly enforced.
Target Profile	Production privileged access operates through a Just-in-Time access model. Access control lists are reviewed quarterly, separation of duties is documented, and MFA is enforced for all applicable accounts.
Gap	Standing privileged access remains in production, periodic access reviews are absent, separation of duties is undocumented, and MFA enforcement is inconsistent.

PR.DS-01 — Data at Rest Protected

Assessment Area	Profile
Current Profile	Encryption at rest is enabled for the primary AWS RDS transaction database. However, encryption coverage across other systems and third-party platforms has not been comprehensively documented.
Target Profile	Encryption-at-rest requirements are confirmed and documented for all systems storing transaction, payment, or sensitive customer information. A centralized encryption inventory is maintained, and key management and rotation requirements are formally defined.

Assessment Area	Profile
Gap	No complete encryption inventory exists, encryption coverage outside the primary database is not fully confirmed, and key rotation requirements are not formally documented.

PR.DS-02 — Data in Transit Protected

Assessment Area	Profile
Current Profile	TLS protects merchant portal communications, but encryption between internal services is not consistently implemented. Certificate inventory and expiry monitoring are also absent.
Target Profile	TLS 1.2 or higher is enforced across external-facing services. Internal service-to-service encryption is consistently implemented, and certificate inventory and automated expiry alerting are maintained.
Gap	Internal encryption coverage is incomplete, and no formal certificate monitoring or inventory exists.

5. DETECT Function

DE.CM-01 — Networks and Services Monitored for Adverse Events

Assessment Area	Profile
Current Profile	Basic AWS CloudWatch logging is enabled, but logs are not centrally correlated or actively monitored through a SIEM. No specific detection rules exist for anomalous privileged account activity, unusual production access, or bulk data export events.
Target Profile	Centralized monitoring is implemented through a SIEM or equivalent monitoring platform. Detection rules monitor anomalous administrative logins, after-hours production access, and unusual data export activity. A defined alert escalation and on-call process supports continuous monitoring.
Gap	Logging exists but active monitoring and detection capabilities are insufficient. This creates a distinction between collecting security logs and actually detecting security events.

DE.CM-09 — Endpoint Hardware and Software Monitored

Assessment Area	Profile
Current Profile	Developer endpoints do not have a centralized endpoint monitoring or device management capability. Device loss or theft may therefore occur without sufficient visibility into potential unauthorized access or compromise.
Target Profile	Mobile Device Management and endpoint monitoring are deployed across developer devices. Controls include device inventory, unauthorized software detection, remote wipe capability, and login anomaly monitoring.
Gap	Endpoint visibility and monitoring are limited, leaving device loss and compromise risks without adequate detective coverage.

6. RESPOND AND RECOVER Functions

RS.CO-02 — Stakeholders Notified of Cybersecurity Incidents

Assessment Area	Profile
Current Profile	No formal incident notification procedure exists. Merchant notification obligations have been identified, but notification responsibilities and timelines have not been operationalized.
Target Profile	An Incident Response playbook defines stakeholder notification procedures, escalation responsibilities, internal reporting timelines, customer communication requirements, and applicable regulatory notification requirements.
Gap	No formal incident notification playbook or operational procedure exists.

RC.RP-01 — Recovery Plan Executed During or Following an Incident

Assessment Area	Profile
Current Profile	No documented or tested Business Continuity and Disaster Recovery plan exists. Recovery objectives and failover procedures have not been formally defined.
Target Profile	A documented and tested BCDR program defines Recovery Time Objectives and Recovery Point Objectives by system criticality. AWS failover procedures are documented and tested through periodic exercises.
Gap	No BCDR plan, RTO/RPO definition, or tested recovery procedure currently exists.

7. Key Findings from the CSF Profile

The Profile identified several cross-functional themes that significantly affect PaySphere's overall cybersecurity posture.

Governance Maturity

The organization has identified risks but lacks sufficient formalization around:

- Risk appetite
- Executive oversight
- Risk ownership
- Security policies

This creates a gap between risk awareness and mature risk governance.

Privileged Access Risk

Privileged access remains one of the most significant control gaps because of:

- Standing administrative access
 - Inconsistent MFA enforcement
 - Absence of periodic access reviews
 - Limited separation of duties
 - Insufficient detection for anomalous privileged activity
-

Third-Party Risk

Critical vendor dependencies are not yet supported by a sufficiently mature vendor risk management process.

The major concerns include:

- Concentration risk
 - Incomplete vendor assessments
 - Limited monitoring
 - Lack of standardized vendor risk records
 - Insufficient contingency planning for critical suppliers
-

Detection and Monitoring

PaySphere collects security logs but has limited capability to convert those logs into actionable detection.

This highlights an important cybersecurity principle:

Logging alone does not provide effective detection without monitoring, alerting, investigation, and response processes.

Resilience and Recovery

The absence of a formal BCDR capability remains a multiplier risk because the inability to recover effectively can amplify the impact of other cybersecurity incidents.

8. Project B — Razorpay Vendor Risk Record

8.1 Objective

The second project operationalizes the NIST CSF 2.0 requirement represented by **GV.SC-07**.

The objective was to create a practical vendor risk record demonstrating how a critical supplier's cybersecurity and operational risks can be:

- Identified
- Recorded
- Prioritized
- Treated
- Monitored
- Escalated

Razorpay was selected because it represents a critical payment processing dependency for PaySphere.

PAYSPHERE — VENDOR RISK RECORD

Vendor Identification

Field	Details
Vendor Name	Razorpay Software Private Limited
Record ID	VRR-002b
Linked Risk Register Entry	PSR-002b — Critical Vendor Concentration Risk
Record Owner	Head of Compliance / CISO
Review Frequency	Quarterly
Next Scheduled Review	Quarterly cadence

9. Service Description

Razorpay provides PaySphere's primary payment gateway and settlement infrastructure.

The service supports:

- Merchant payment processing
- Transaction routing
- Payment processing operations
- Settlement disbursement to merchant accounts

PaySphere currently does not maintain an operational alternative payment gateway. This creates significant dependency and concentration risk because disruption to Razorpay could directly affect PaySphere's transaction processing capability.

10. Vendor Criticality Assessment

Risk Factor	Rating	Assessment Basis
Financial Criticality	Critical	A significant dependency exists on Razorpay for payment transaction processing and business operations.
Data Access Scope	High	The service processes sensitive transaction information and merchant-related data.
Substitutability	Low	No immediately available secondary gateway exists, and replacement would require significant implementation effort.
Geographic Concentration	High	Operational dependency is concentrated without an established alternative regional failover path.
Regulatory Exposure	High	The vendor's regulatory and operational posture can directly affect PaySphere's compliance obligations.

Overall Vendor Risk Tier: CRITICAL

The vendor is classified as Critical because a failure, compromise, or significant regulatory issue could materially affect PaySphere's:

- Revenue generation
- Merchant operations
- Payment processing capability
- Regulatory posture
- Customer trust

11. Security Attestation Tracker

Document	Status	Review Considerations	Monitoring Requirement
SOC 2 Type II Report	Received	Review applicable Trust Services Criteria and identified exceptions relevant to PaySphere's use case.	Track report period and renewal date. Escalate overdue evidence.
Data Processing Agreement	Active	Review data processing obligations, breach notification requirements, and data handling responsibilities.	Reassess during contract renewal or material service changes.
Payment Regulatory Authorization	Verified	Confirm regulatory standing and applicability to the service relationship.	Periodic verification.
Penetration Test Evidence	Requested/Pending	Review available independent testing evidence when provided.	Track request and escalate if evidence remains unavailable.

The attestation review process is intended to evaluate not simply whether documentation has been received, but whether the evidence:

- Covers the relevant service period
 - Applies to PaySphere's use case
 - Identifies material control exceptions
 - Requires compensating controls
 - Needs renewal or follow-up
-

12. Contractual Security Requirements

The vendor relationship should be assessed against contractual security requirements including:

Requirement	Status	Risk Management Consideration
Data breach notification	Confirmed through contractual obligations	Notification requirements must support PaySphere's regulatory obligations.

Requirement	Status	Risk Management Consideration
Data minimization	Confirmed	Vendor should only process information necessary for the contracted service.
Audit and assurance rights	Partially available	Reliance may be placed on independent assurance reports where direct audit rights are limited.
Encryption in transit	Confirmed	Secure communication requirements apply to payment and API interactions.
Subprocessor notification	Confirmed	Material changes to subprocessors should trigger additional risk review.

13. Risk Treatment Assessment

Risk Factor	Current Treatment	Residual Risk	Owner
No secondary payment gateway	Risk remains open pending business and engineering investment decisions.	High	CTO
Security assurance renewal gaps	Evidence requests and escalation procedures established.	Medium	Head of Compliance
Limited independent testing evidence	Additional assurance documentation requested from vendor.	Medium	Head of Compliance
Regulatory dependency	Regulatory standing periodically verified.	Low after treatment	Compliance

14. Vendor Monitoring and Review Cadence

Vendor risk management must continue after onboarding.

The following monitoring triggers are established for the Razorpay relationship.

Trigger	Required Action	Owner
Quarterly Review	Review vendor risk record, update assurance documentation, review security events, and reassess criticality.	Head of Compliance
Vendor Security Incident	Perform an out-of-cycle risk reassessment and notify senior security leadership.	CISO
Expired Security Assurance Evidence	Escalate overdue evidence and assess the impact on vendor risk status.	Head of Compliance
Subprocessor Change	Assess changes to data access and security exposure.	Compliance

Trigger	Required Action	Owner
Contract Renewal	Perform full contractual and security requirement review.	Legal and Compliance

15. Risk Acceptance and Escalation

The absence of a secondary payment gateway represents a significant residual concentration risk.

This risk should not be treated as an informal operational assumption. If accepted, it must be formally documented and approved by the appropriate risk owners.

The risk acceptance should include:

- Description of the accepted risk
- Business justification
- Risk owner
- Approval authority
- Date of acceptance
- Review date
- Conditions that trigger reassessment

Recommended reassessment triggers include:

- Significant increase in transaction volume
- Major Razorpay service disruption
- Material security incident
- Regulatory action affecting the vendor
- Significant deterioration in vendor security posture

This ensures that risk acceptance remains an active management decision rather than becoming a permanent unmanaged exception.

16. Final Deliverables

The Week 5 project produced two primary GRC artifacts.

Deliverable 1: PaySphere NIST CSF 2.0 Current and Target Profile

The Profile demonstrates the ability to:

- Select relevant NIST CSF 2.0 Subcategories

- Assess a Current Profile based on available organizational evidence
 - Define a measurable Target Profile
 - Identify explicit capability gaps
 - Connect framework requirements to known organizational risks
 - Use the Profile as a roadmap for cybersecurity improvement
-

Deliverable 2: Critical Vendor Risk Record

The Vendor Risk Record demonstrates the ability to:

- Assess vendor criticality
 - Evaluate third-party risk factors
 - Track security assurance documentation
 - Review contractual security requirements
 - Assign risk ownership
 - Define risk treatment activities
 - Establish ongoing monitoring
 - Document risk acceptance and escalation triggers
-

17. Key GRC Competencies Demonstrated

Through this project, the following practical competencies were demonstrated:

Cybersecurity Framework Application

Applying NIST CSF 2.0 requirements to a realistic organizational environment.

Current-State Assessment

Documenting what actually exists rather than assigning generic implementation labels.

Target-State Definition

Defining specific, measurable, and actionable cybersecurity outcomes.

Gap Analysis

Identifying the precise difference between the organization's existing and desired capabilities.

Risk-Based Prioritization

Selecting framework areas based on material organizational risks.

Third-Party Risk Management

Assessing vendor criticality, security evidence, contractual obligations, residual risk, and monitoring requirements.

Governance and Accountability

Establishing risk ownership, review cadences, escalation processes, and documented risk acceptance.

GRC Documentation

Producing structured artifacts suitable for management review, audit preparation, and portfolio demonstration.

Conclusion

Week 5 focused on converting cybersecurity risk knowledge into operational GRC artifacts.

The PaySphere CSF 2.0 Profile demonstrates how a GRC analyst can assess an organization's security posture, define a realistic target state, and identify the gaps requiring remediation.

The Razorpay Vendor Risk Record demonstrates how a framework requirement can be operationalized into a repeatable third-party risk management process rather than treated as a high-level compliance statement.

Together, these deliverables show the progression from:

Risk Identification → Framework Mapping → Current-State Assessment → Target-State Definition → Gap Analysis → Risk Treatment → Continuous Monitoring

The central outcome of this week's work is the ability to transform cybersecurity and compliance requirements into structured, decision-useful artifacts that can support leadership, security teams, auditors, and risk owners.

Week 5 Deliverable Completed: NIST CSF 2.0 Profile Assessment and Critical Vendor Risk Management Record.